ATEBIZ · NEXTREPORTING

Política de Seguridad de la Información

Versión 1.0 · Julio 2026

---

1. INTRODUCCIÓN

La presente Política establece el marco general de seguridad de la información aplicable a las actividades operativas, tecnológicas y comerciales de ATEBIZ («Empresa»), incluidos el desarrollo, la explotación y la comercialización de la plataforma NEXTREPORTING.

Su objetivo es garantizar niveles apropiados de confidencialidad, integridad y disponibilidad de los datos gestionados por la Empresa.

La Política se aplica a todo el personal, colaboradores externos, contratistas y proveedores que traten información de la Empresa o de sus clientes.

2. GOBIERNO DE LA SEGURIDAD

La Empresa dispone de una estructura de gobierno de la seguridad de la información con roles y responsabilidades claramente asignados.

Un responsable de seguridad de la información supervisa la aplicación efectiva de las políticas, procedimientos y controles.

La dirección revisa periódicamente el estado del programa de seguridad y aprueba las principales decisiones estratégicas en la materia.

3. GESTIÓN DE RIESGOS

La Empresa realiza evaluaciones de riesgo periódicas orientadas a identificar amenazas relevantes, valorar su impacto potencial y determinar las medidas de mitigación adecuadas.

Las evaluaciones consideran tanto amenazas técnicas como organizativas y regulatorias.

Los riesgos se tratan mediante controles proporcionados y documentados, con seguimiento periódico de su eficacia.

4. CONTROL DE ACCESOS

El acceso a los sistemas de información se otorga conforme al principio de mínimo privilegio y necesidad de conocer.

Los permisos se revisan periódicamente y se retiran con celeridad cuando dejan de ser necesarios.

Se aplican mecanismos de autenticación robustos, incluidos, cuando proceda, factores adicionales de autenticación.

Los accesos privilegiados están sujetos a controles reforzados y registros específicos.

5. SEGURIDAD DE LOS DATOS

La información se protege mediante cifrado en tránsito y, cuando proceda, en reposo, utilizando algoritmos y configuraciones alineados con las buenas prácticas del sector.

Los datos sensibles se someten a controles adicionales de protección y a políticas específicas de retención y disposición.

Las copias de seguridad se realizan periódicamente y se protegen adecuadamente frente a acceso no autorizado.

6. SEGURIDAD DE LAS APLICACIONES

Los procesos de desarrollo incorporan prácticas de codificación segura, revisiones de código y pruebas de seguridad proporcionadas al nivel de riesgo.

Las vulnerabilidades detectadas se priorizan y remedian conforme a criterios de gravedad e impacto.

Los cambios en los entornos productivos se gestionan mediante procedimientos formales de control.

7. SEGURIDAD DE INFRAESTRUCTURA

La infraestructura tecnológica se mantiene actualizada, configurada de forma segura y protegida por controles perimetrales, segmentación y monitorización.

Se realizan tareas periódicas de aplicación de parches y hardening.

Los proveedores cloud utilizados cumplen estándares reconocidos internacionalmente.

8. GESTIÓN DE INCIDENTES

La Empresa dispone de procedimientos formales de gestión de incidentes de seguridad, orientados a la detección temprana, respuesta rápida, contención, investigación y recuperación.

Los incidentes que puedan afectar a datos de clientes se comunican conforme a las obligaciones contractuales y legales aplicables.

9. RECURSOS HUMANOS Y CONCIENCIACIÓN

El personal recibe formación periódica en seguridad de la información y protección de datos.

Los responsables del tratamiento de datos personales asumen deberes de confidencialidad y se rigen por políticas internas específicas.

10. GESTIÓN DE PROVEEDORES

Los proveedores con acceso a información de la Empresa o de sus clientes se seleccionan mediante procesos de diligencia debida proporcionados al riesgo.

Los contratos incluyen cláusulas de seguridad y confidencialidad apropiadas.

11. CONTINUIDAD DE NEGOCIO

La Empresa mantiene planes de continuidad de negocio y recuperación ante desastres proporcionados a la naturaleza del servicio.

Los planes se someten a pruebas periódicas y se actualizan conforme evolucionan los riesgos y la infraestructura.

12. CUMPLIMIENTO Y AUDITORÍA

La Empresa cumple la legislación aplicable en materia de protección de datos, seguridad y confidencialidad.

Se realizan revisiones internas periódicas del programa de seguridad y, cuando proceda, evaluaciones o auditorías por terceros independientes.

13. REVISIÓN DE LA POLÍTICA

La presente Política será revisada al menos anualmente o cuando se produzcan cambios significativos en el entorno tecnológico, regulatorio o de negocio.

Las actualizaciones aprobadas serán publicadas y comunicadas conforme a los procedimientos internos de gestión documental.